



Intrusion Detection and Prevention (IPS/IDS)

New Generation Firewall (NGFW)

■ Why a Firewall Is Not Enough

- Attacks that bypass classic firewall controls (e.g., tunneling, application abuse)
- Malicious or careless insider activity
- Regulatory requirements (banking, healthcare, government)
- Need for real-time detection plus incident forensics



Intrusion Detection and Prevention



Detection vs. Prevention

IDS alerts • IPS blocks

IDS — Detection



- Monitors traffic, events, and logs
- Detects suspicious activity
- Generates alerts (no blocking)
- Best for visibility and forensics

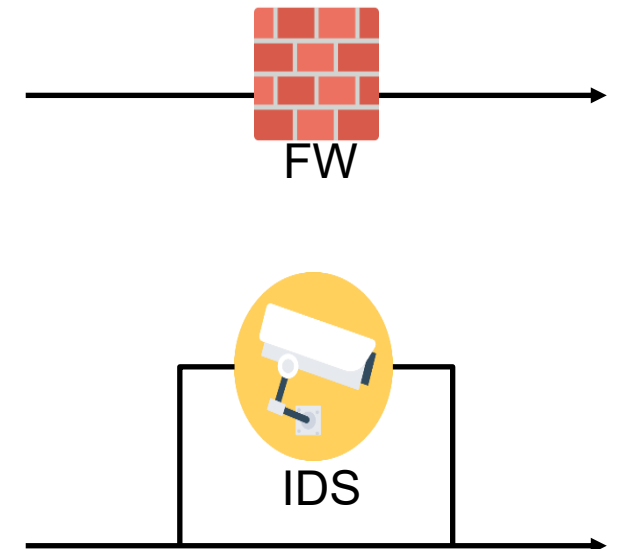
IPS — Prevention



- Sits inline in the traffic path
- Detects and blocks immediately
- Can drop packets or block IPs/users
- False positives can impact business

DIFFERENCES BETWEEN FIREWALLS AND IDS

- What is the difference between firewalls and network-based Intrusion Detection Systems?
- Firewall
 - Active filtering
 - Detection methods: IP address, Port, protocols
- Network-based IDS
 - Passive monitoring
 - Detection methods: Knowledge-based (or signature-based), Behavior-based



Where IDS/IPS fit

Security stack (simplified)

- Firewalls allow/deny by IP, port, app policies
- IDS observe traffic/hosts and raise alerts
- IPS actively block/suppress malicious activity
- SIEM/SOC collect events + investigate
- EDR endpoint behavior detection & response

IDS/IPS are detection + control layers complement firewalls, they don't replace them.

Traffic & Events

Firewall / WAF

policy gate

IDS / IPS

detect & (maybe)
block

SIEM / SOC

investigate &
respond

EDR / Host controls

endpoint signals

users / apps

services / data

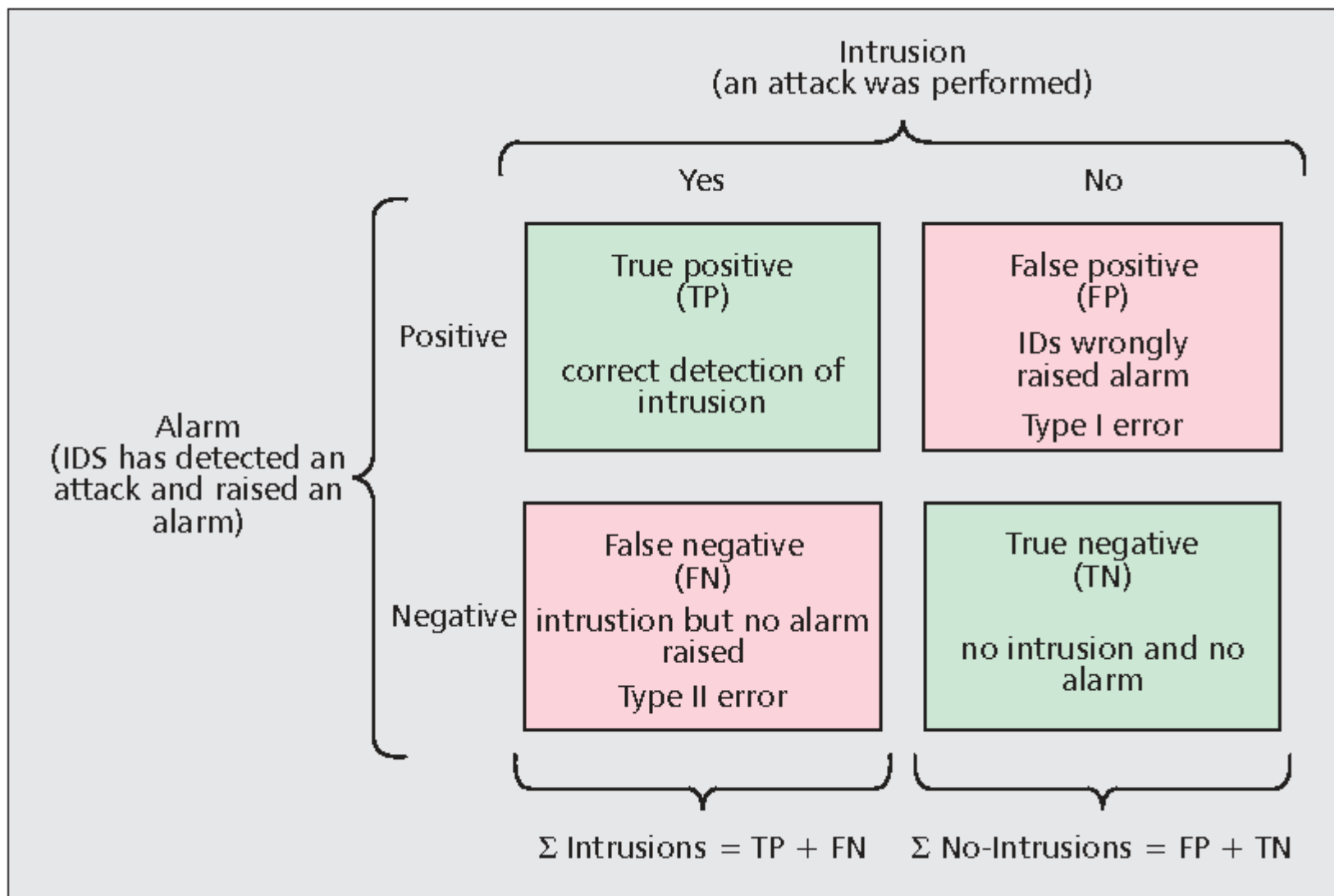
Gatekeeping

Endpoint context

Detect/Prevent

Incidents happen anyway -
respond

IDS Confusion Matrix



False positives vs false negatives

Trade-off

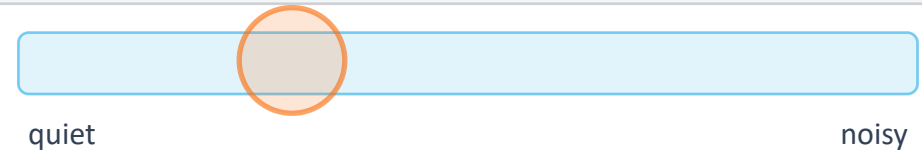
- Too sensitive → alert fatigue → ignored alerts
- Too quiet → missed attacks
- Goal is to increase precision without killing recall

Reduce operational cost while protecting critical processes.

Tuning spectrum

More sensitive → more alerts (incl. false positives)

Tune by asset criticality + likelihood, then validate with testing & incidents.



Risk if too quiet
Missed detections
(false negatives)

Risk if too noisy
Alert fatigue (false positives)

IDS in one sentence

IDS

An Intrusion Detection System monitors network or host activity and generates alerts when it sees suspicious or known-malicious behavior.

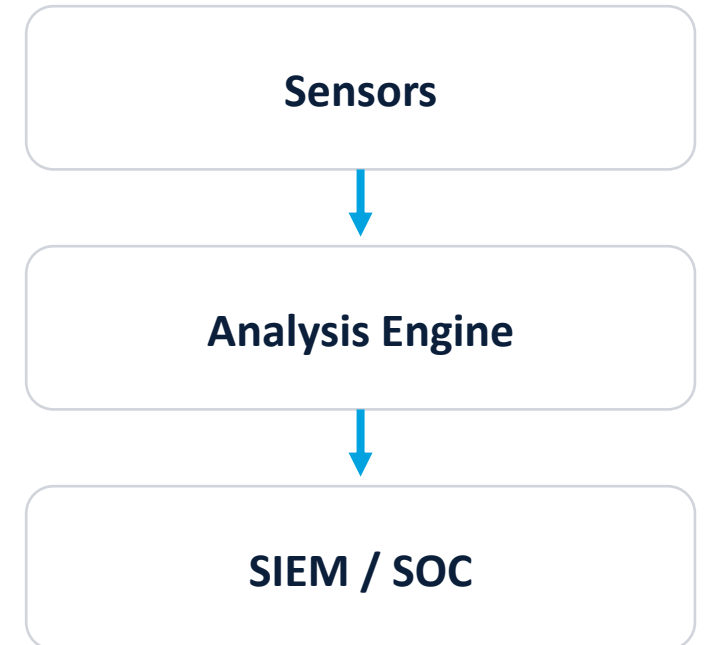
Think: security camera + motion detector, it watches and tells you when something looks wrong.



IDS

- Monitors and detects intrusion attempts and abnormal activity
- Collects data: network traffic, logs, host events
- Matches against attack signatures or a baseline of normal behavior
- Sends alerts to the SOC / SIEM

Typical flow



IDS observes and alerts.
It does not block traffic by default.

IDS categories

Common IDS forms

- NIDS: network-based (sees traffic)
- HIDS: host-based (sees system activity)
- Cloud IDS: VPC/VNet flow + logs

IDS doesn't usually...

- Stop traffic by itself
- Fix vulnerabilities
- Replace incident response

IDS is detection. You still need response.

How an IDS "thinks"

Typical stages

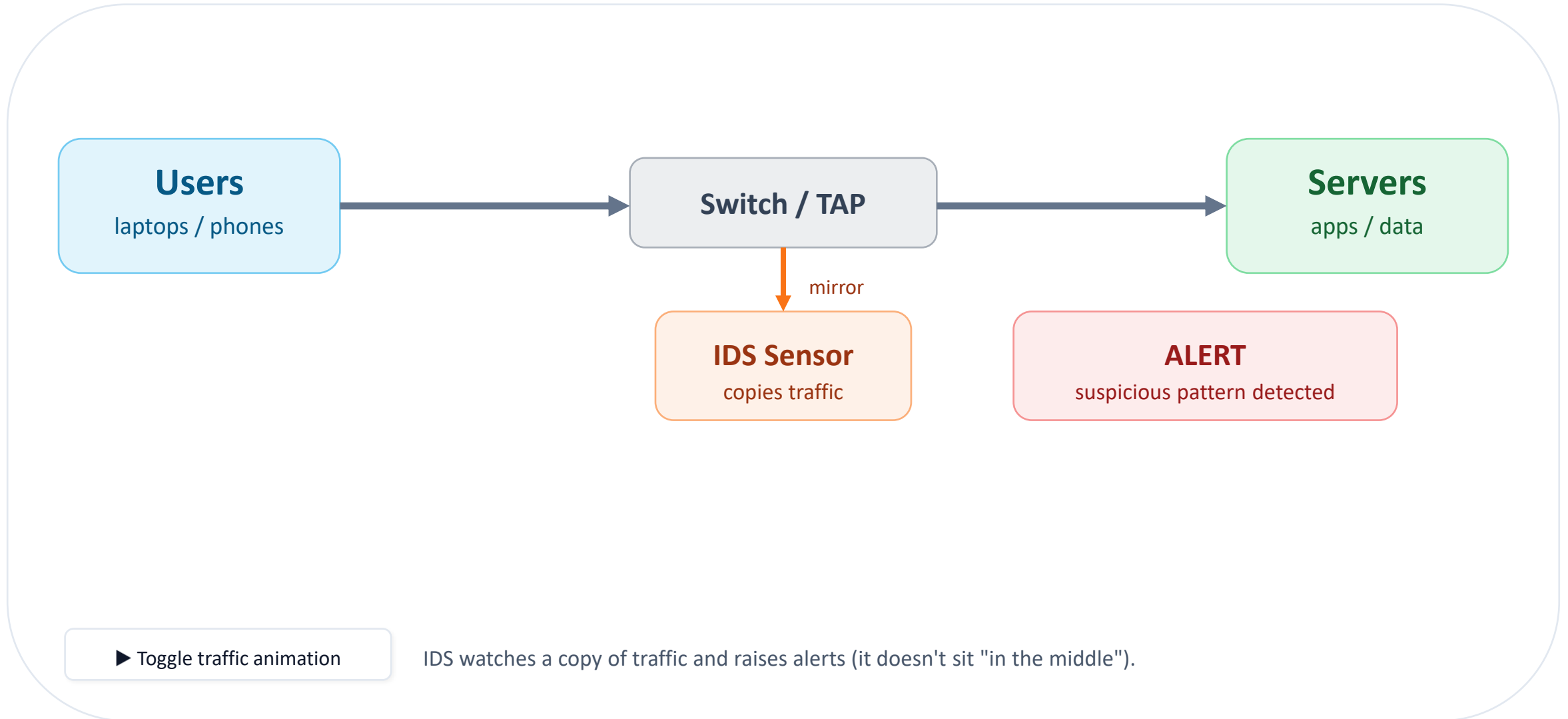
1. Capture traffic / events
2. Decode protocols (HTTP, DNS, SMB...)
3. Normalize data (remove tricks / ambiguity)
4. Detect (rules, anomalies, reputation)
5. Alert + enrich (who/what/where)
6. Log to SIEM / case mgmt

What it needs

- Visibility: right traffic + logs
- Context: assets, users, criticality
- Tuning: reduce noise, keep coverage

"Good IDS" is often more about operations than technology.

NIDS



Detection method #1: Knowledge Signature / rules

Idea

- Match known bad patterns: strings, domains, hashes, protocol fields
- Fast and explainable
- Needs updates (new threats → new signatures)

● Often lower false positives

● Misses unknown attacks

Example (simplified)

```
alert tcp any any -> $HOME_NET 80 (  
  msg:"Possible SQL injection attempt";  
  content:"' OR 1=1"; nocase;  
  sid:1000001; rev:1;  
)
```

Rule formats vary, but the concept is the same: if pattern X appears in context Y → alert.

Knowledge-based IDS

Knowledge-based IDS only as good as database of attack signatures:

- New vulnerabilities not in the database are constantly being discovered and exploited;
- Vendors need to keep up to date with latest attacks and issue database updates - Customers need to install these;
- Large number of vulnerabilities and different exploitation methods, so effective database difficult to build;
- Large database makes IDS slow to use.

Knowledge Based IDS

High accuracy, but low in completeness

Drawback: need regular **update of knowledge**
(malware signatures)

High performance with minimal processing
power

Detection method #2: Anomaly / behavior

Idea

- Learn "normal" and flag unusual behavior
- Helpful for unknown attacks & insider threats
- Risk: higher false positives if baseline is weak

In business systems, "normal" changes often (new apps, seasonal spikes).

Examples of anomaly signals

- Unusual data exfil volume at 2:00am
- DNS queries to never-before-seen domains
- Service account login from a new country
- New protocol inside a restricted segment

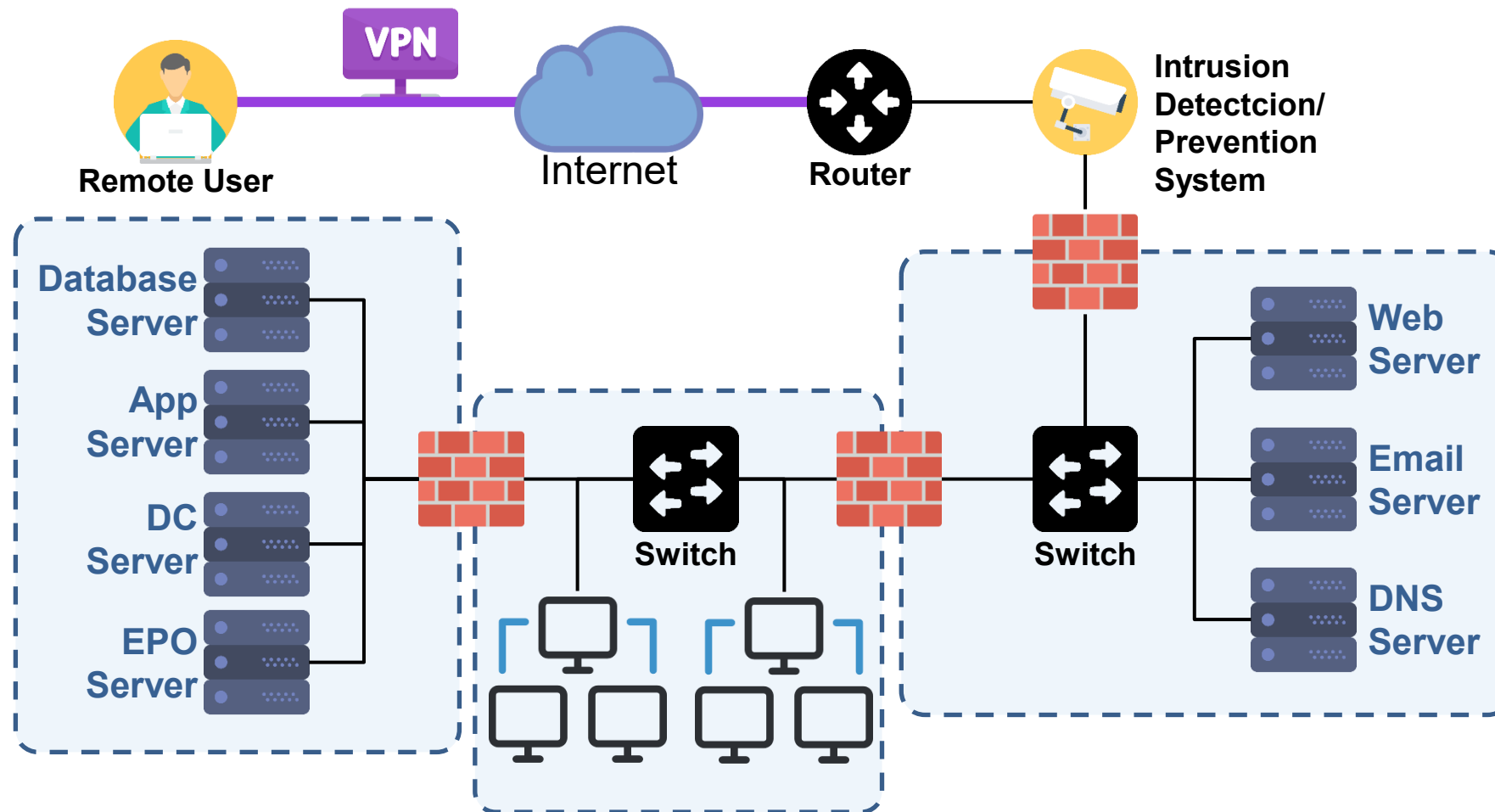
Behavior Based IDS

High in completeness, but low accuracy

Detect intrusion by observing a **deviation from the normal** or expected behavior of the system or the users

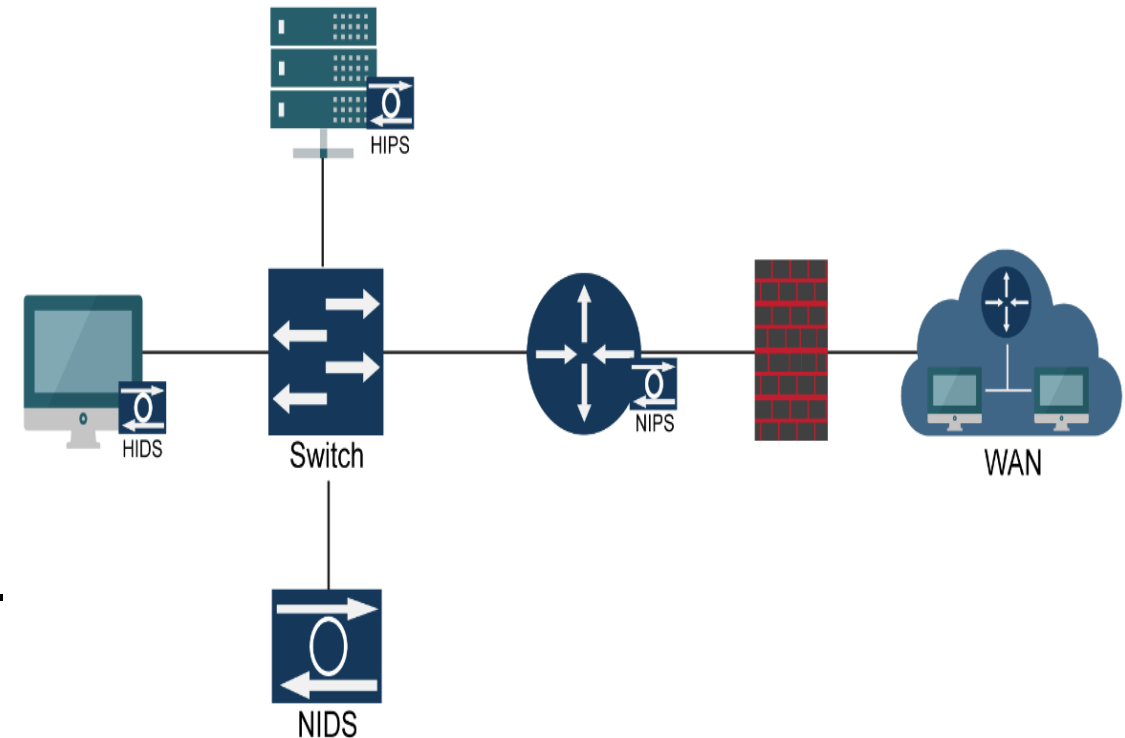
Can detect attempts to exploit new and unforeseen vulnerabilities (zero-day attacks)

IPS within Typical Corporate Environment



NIDS and HIDS

- Network-based systems (NIDS or NIPS) are placed on routers or other network choke points and focus primarily on detecting network attacks, probes, or other suspicious traffic on the network level. They can protect entire subnets and give the big picture of network activity.
 - Inline sensors traffic as it passes through and take action based on their findings, much like a firewall.
 - Passive sensors route a copy of incoming traffic to a monitoring port without interfering with its passage.
- Host-based systems (HIDS or HIPS) are placed on individual hosts and devices to protect them. They can monitor traffic to and from their installed hosts

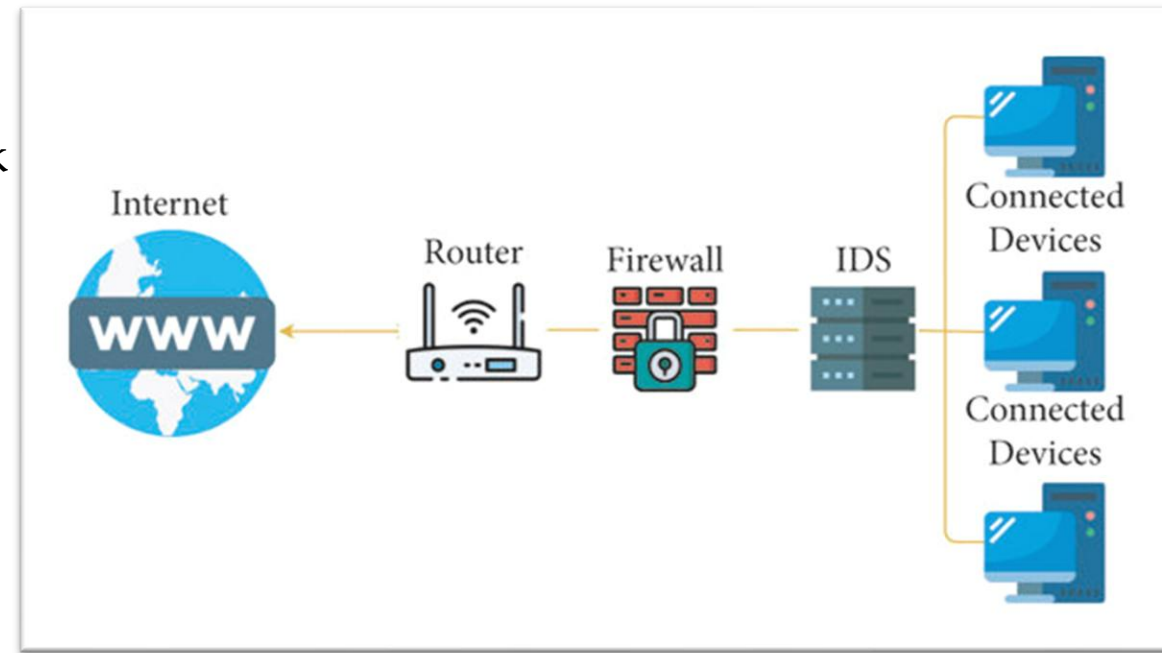


Network-based Intrusion Detection System (NIDS)

- NIDS is implemented in the form of a device that monitors all traffic passing through a strategic point in the network for malicious activities

It is typically deployed at a single point, for example, it can be connected to the network switch (as in the figure)

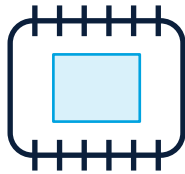
- Monitors and analyzes all traffic in real-time. Attack recognition module uses three common techniques to recognize attack signatures:
 - Pattern, expression or bytecode matching;
 - Frequency or threshold crossing (e.g. detect port scanning activity);
 - Correlation of lesser events (in reality, not much of this in commercial systems).
- If malicious behavior is detected, NIDS will generate alerts to the host or network administrators





Sensors / Probes

Network taps, SPAN ports,
or host agents



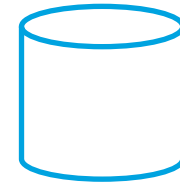
Analysis Engine

Signature and anomaly
logic



Management Console

Policies, rules, dashboards



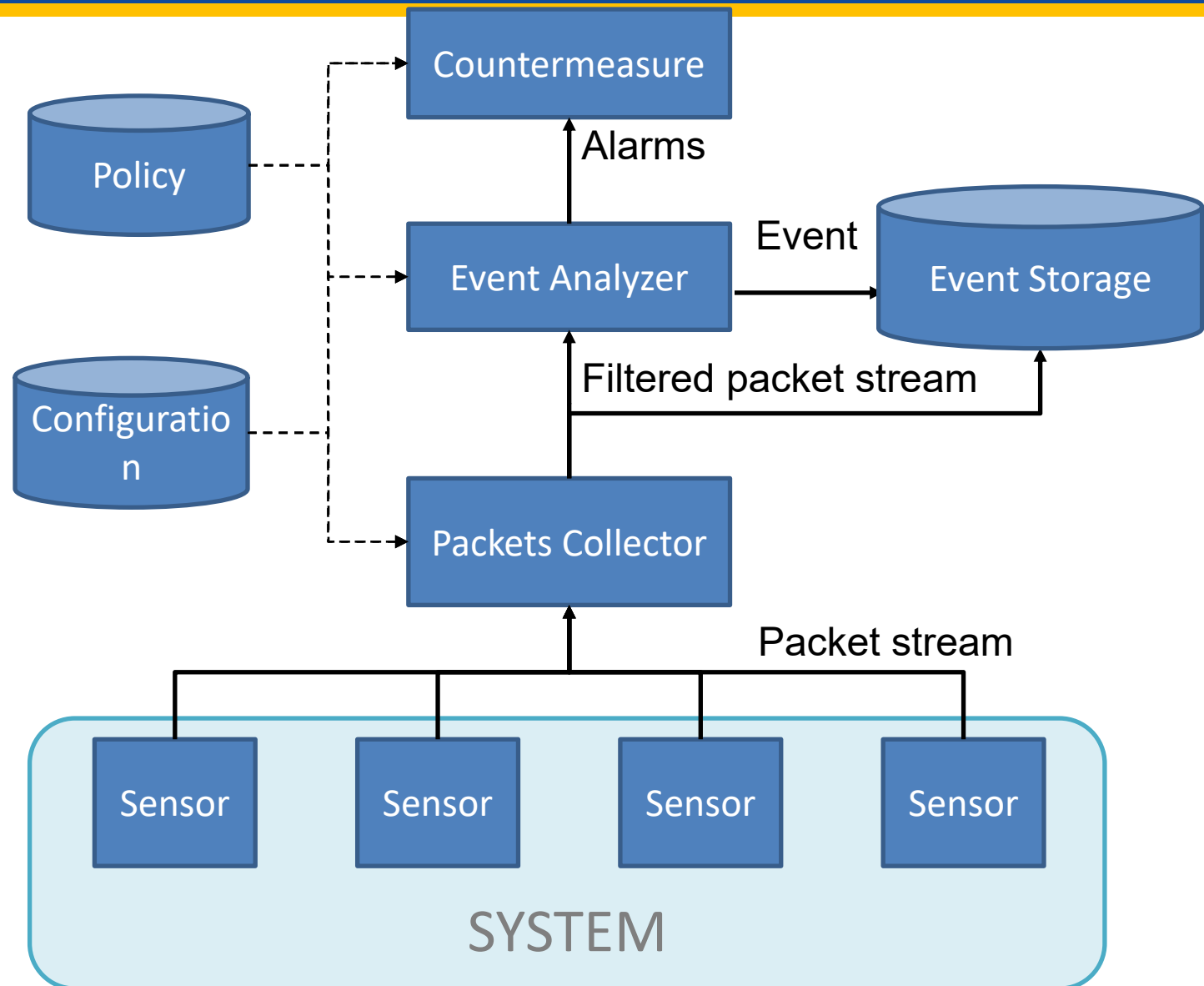
SIEM Integration

Collection, correlation,
reporting

- A modern deployment usually combines multiple sensors and central management.
- SIEM integration is critical for investigation and reporting.

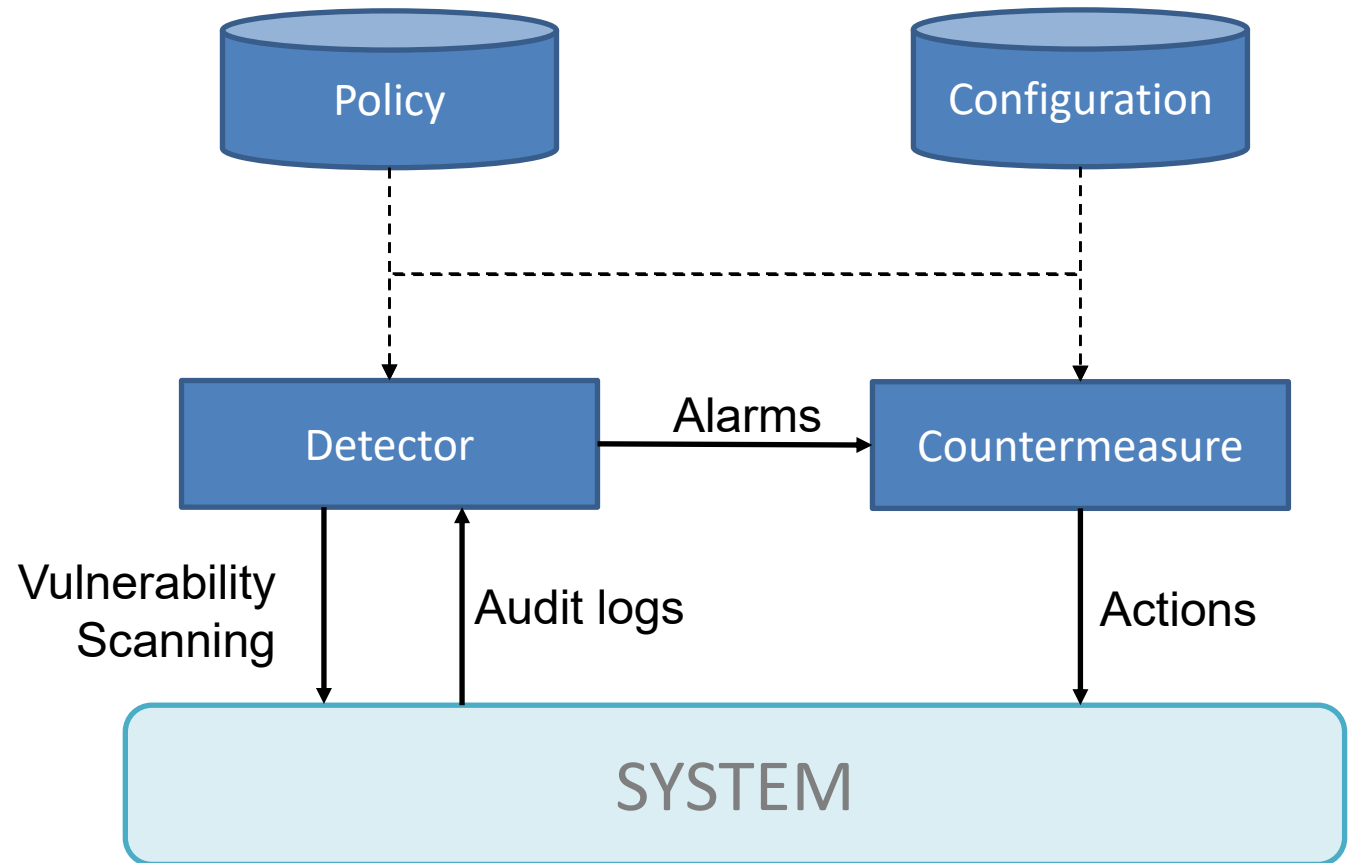
Network-based IDS

- Deploying sensors at strategic locations. E.G., Packet sniffing at routers
- Inspecting network traffic
- Watch for violations of protocols and unusual connection patterns
- Monitoring user activities
- Look into the data portions of the packets for malicious command sequences
- May be easily defeated by encryption
- Data portions and some header information encrypted



Host-based IDS

- Using OS auditing mechanisms
 - **EventLog**: Windows Event Logs, System, Security, Application.
 - **Health**: Read information about CPU, Memory, and Swap usage.
 - **Ps**: Read information about running processes
- Monitoring user activities
 - E.g. analyze shell command
- Monitoring execution of system programs



IPS in one sentence

IPS

An Intrusion Prevention System monitors activity and can actively block or suppress traffic it believes is malicious, usually in real time.

Think: bouncer at the door — it can stop someone from entering.

Common IPS actions

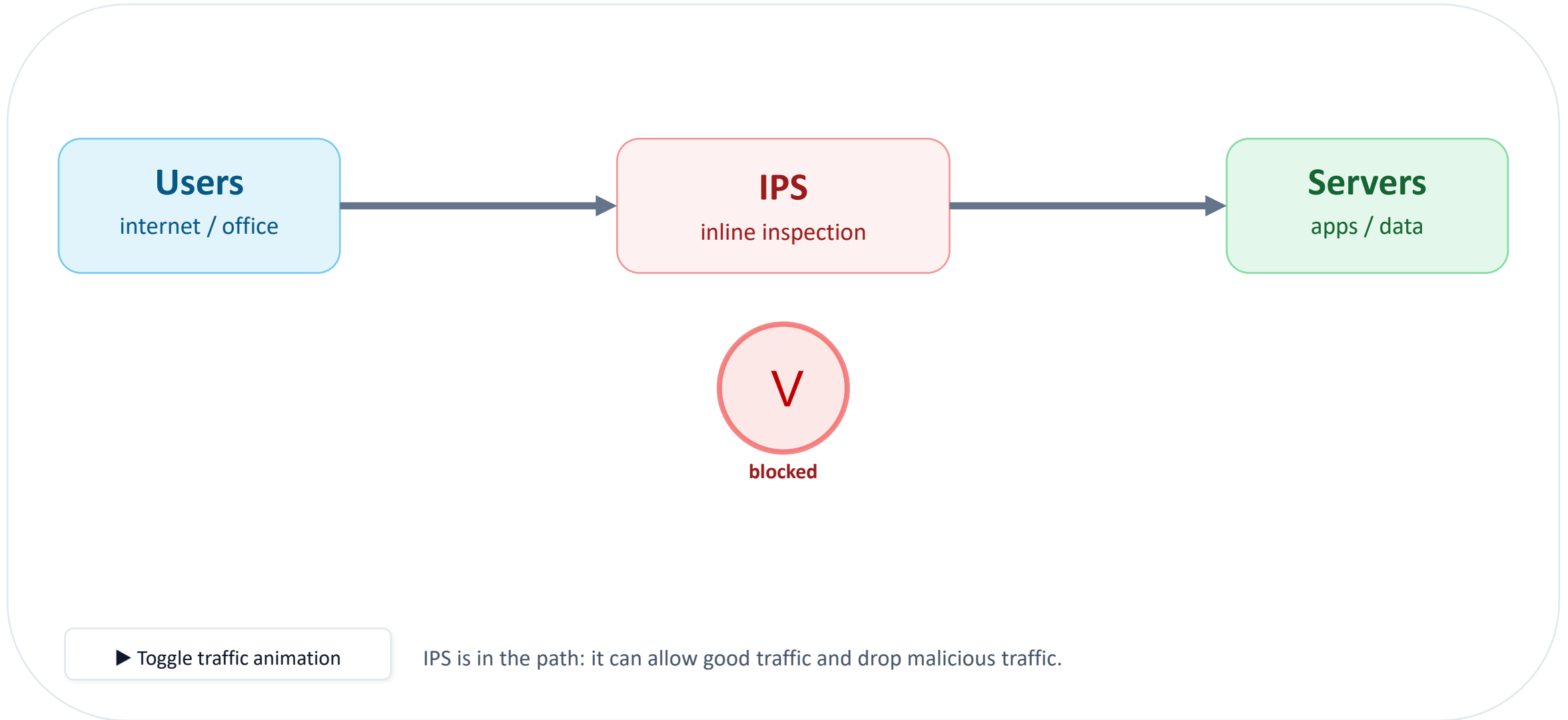
- Drop packets / block flows
- Reset TCP connections
- Rate-limit suspicious behavior
- Quarantine an endpoint (via integration)

Operational reality

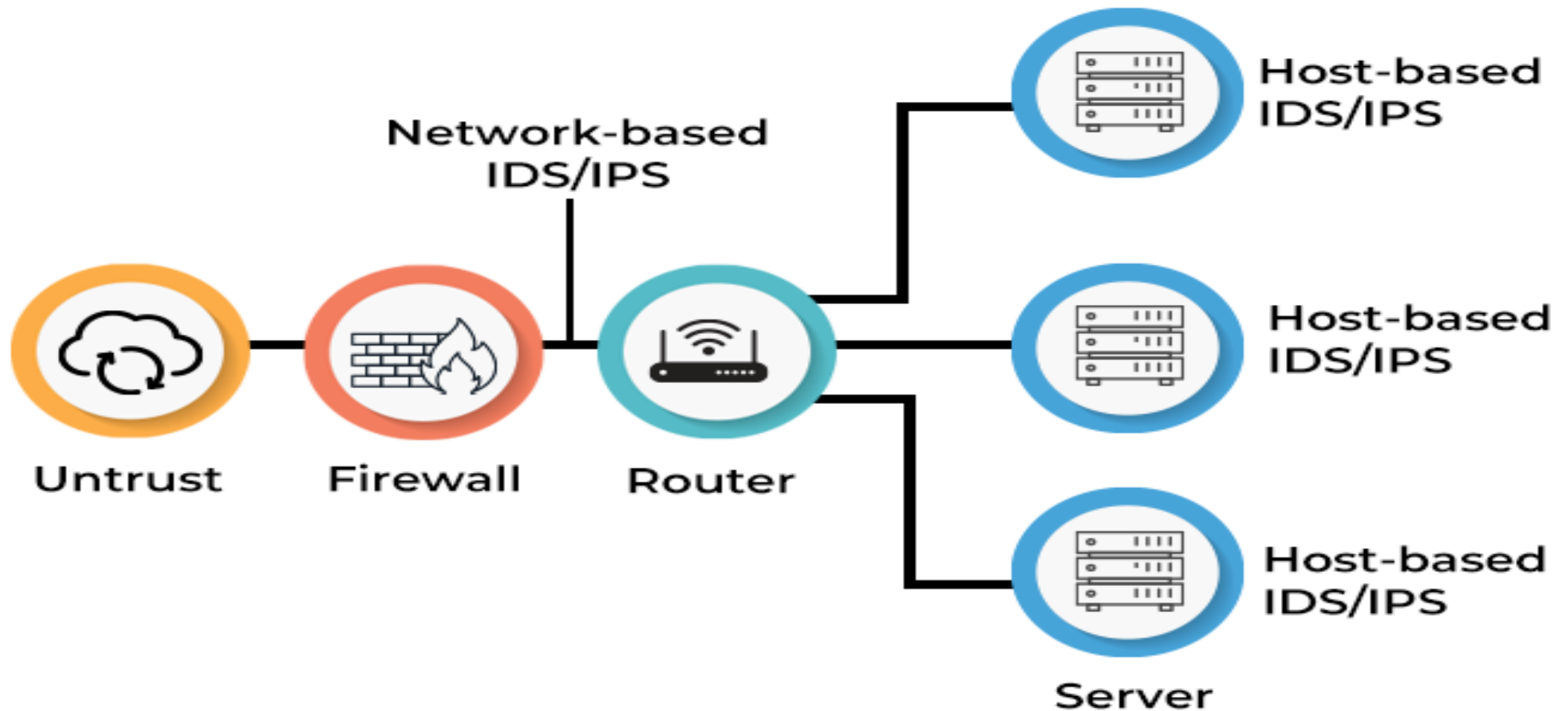
- Blocking errors can cause outages
- Often run in detect-only first
- Change management is critical

IPS is powerful — treat it like a production change.

IPS



IPS/IDS on a Enterprise IT environment



Deployment choices

Network placement

- Perimeter: internet ↔ data center/cloud
- Internal: between segments (user ↔ server)
- DMZ: public-facing services

East-west visibility matters because many breaches spread inside the network.

Host placement

- HIDS/EDR agents on servers/endpoints
- Sees processes, file writes, logins
- Better for encrypted traffic (post-decryption on host)

Encrypted traffic, why it's tricky

The problem

- More traffic is encrypted (TLS/HTTPS)
- Network IDS can't inspect payload without decryption
- Attackers also use encryption to hide

If you only look at encrypted packets, you're mostly seeing "envelopes," not "letters."

Common approaches

- TLS inspection (proxy/decrypt): privacy + key mgmt issues
- Metadata: certs, fingerprints, timing, volume
- Endpoint signals: detection after decryption on host
- App-layer logs: WAF, API gateway, auth logs

IDS vs IPS

IDS

Detection

- Sees traffic/events, raises alerts
- Usually out-of-band (passive)
- Lower risk to availability
- Needs response workflow

IPS

Prevention

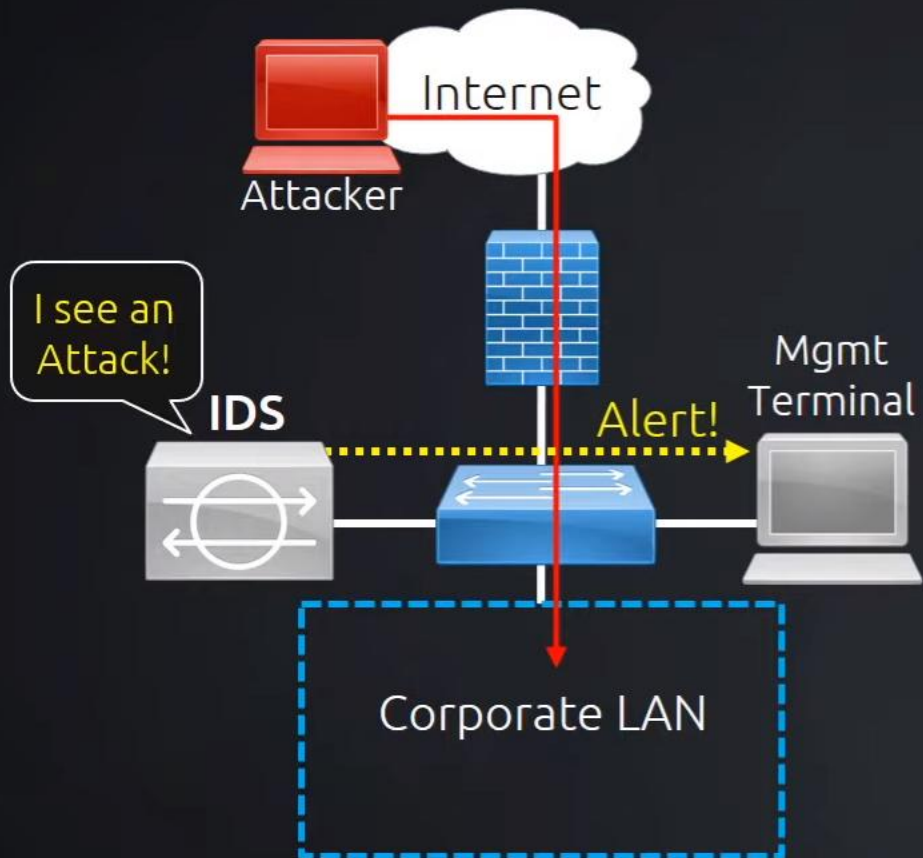
- Can block/drop traffic in real time
- Often inline (adds latency)
- Higher availability risk if wrong
- Requires careful rollout + governance

Best practice: use both appropriately — IDS for visibility + IPS for high-confidence blocking.

IPS vs IDS

Intrusion Detection System

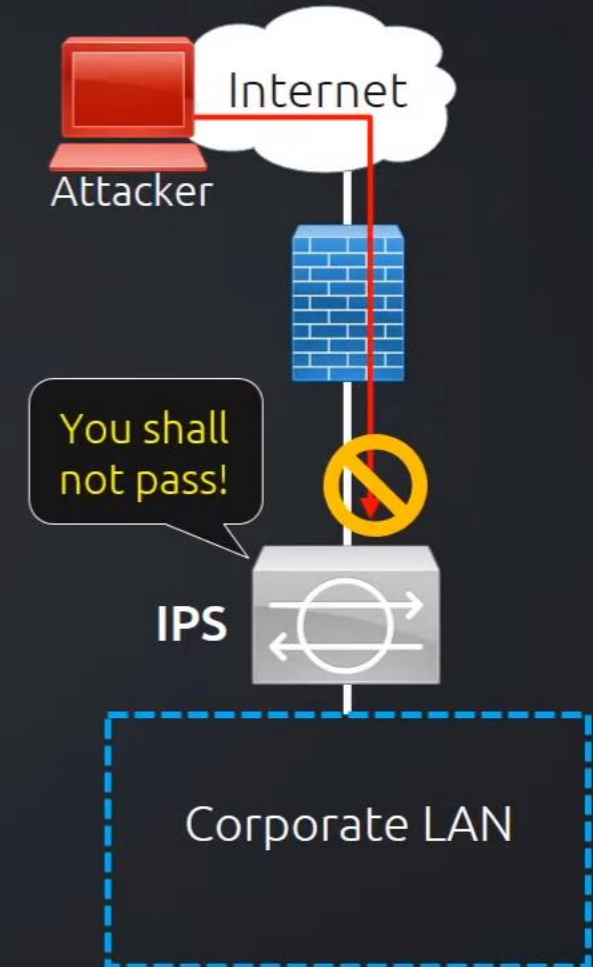
Detects and sends alerts



HIDS - Host-based Intrusion Detection (on computer)
NIDS - Network-based Intrusion Detection (on network)

Intrusion Prevention System

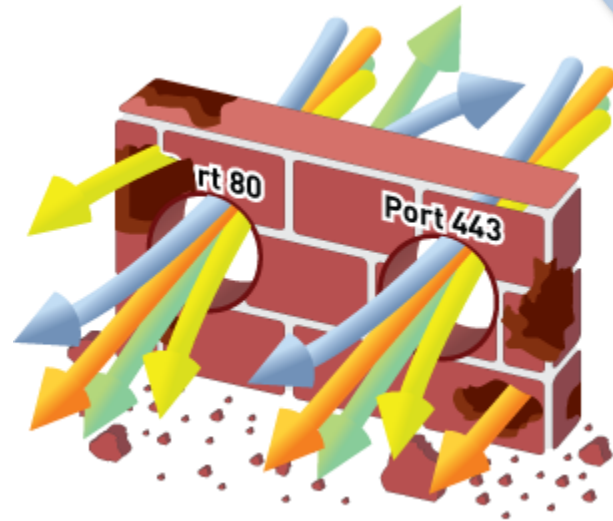
Actively defends the network



Digital Have Changed; Firewalls should too

The gateway at the trust border is the right place to enforce policy control

- Sees all traffic
- Defines trust boundary



BUT...applications have changed

- Ports $\neq$ Applications
- IP Addresses $\neq$ Users
- Packets $\neq$ Content

Need to restore visibility and control in the firewall

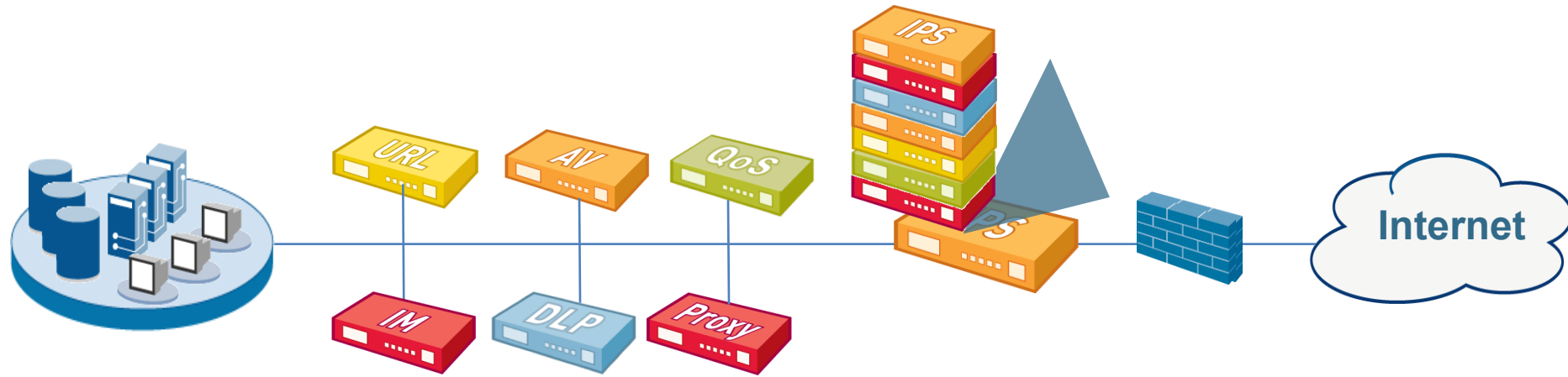
Challenges

- Traditionally, firewalls and intrusion prevention systems block traffic at two completely different levels.
- **A firewall exists to allow or block traffic** based on network protocol and port levels. While this is helpful for blocking some attack methods, attackers are also capable of using legitimate protocols and ports to send malicious traffic over the network.
- Standard firewalls — stateful and stateless — don't perform any packet inspection to determine the quality or legitimacy of traffic, but rather to evaluate the levels of traffic, where the traffic is originating, and so on.

Challenges

- An intrusion prevention system, specifically a NIPS, uses packet inspection as well as anomaly, signature, and policy-based inspections to evaluate whether the traffic is legitimate or not. It's a misconception that if you have a firewall then an IPS solution isn't needed to protect your network (or vice versa). This couldn't be further from the truth. You need both solutions to detect and protect from intrusions on a protocol and packet content level.

Technology Sprawl & Creep Are Not The Answer



- “More stuff” doesn’t solve the problem
- Firewall “helpers” have limited view of traffic
- Complex and costly to buy and maintain

Unified Threat Management (NFW)

- New all-in-one solutions are often called next-generation firewalls (NGFW), or for a less self-dating term, unified threat management (UTM) firewalls.
- Neither is a concrete standard, but rather the concept of putting a complete network security solution into a single centrally controlled system.

The Right Answer: Make the NGFW Do Its Job

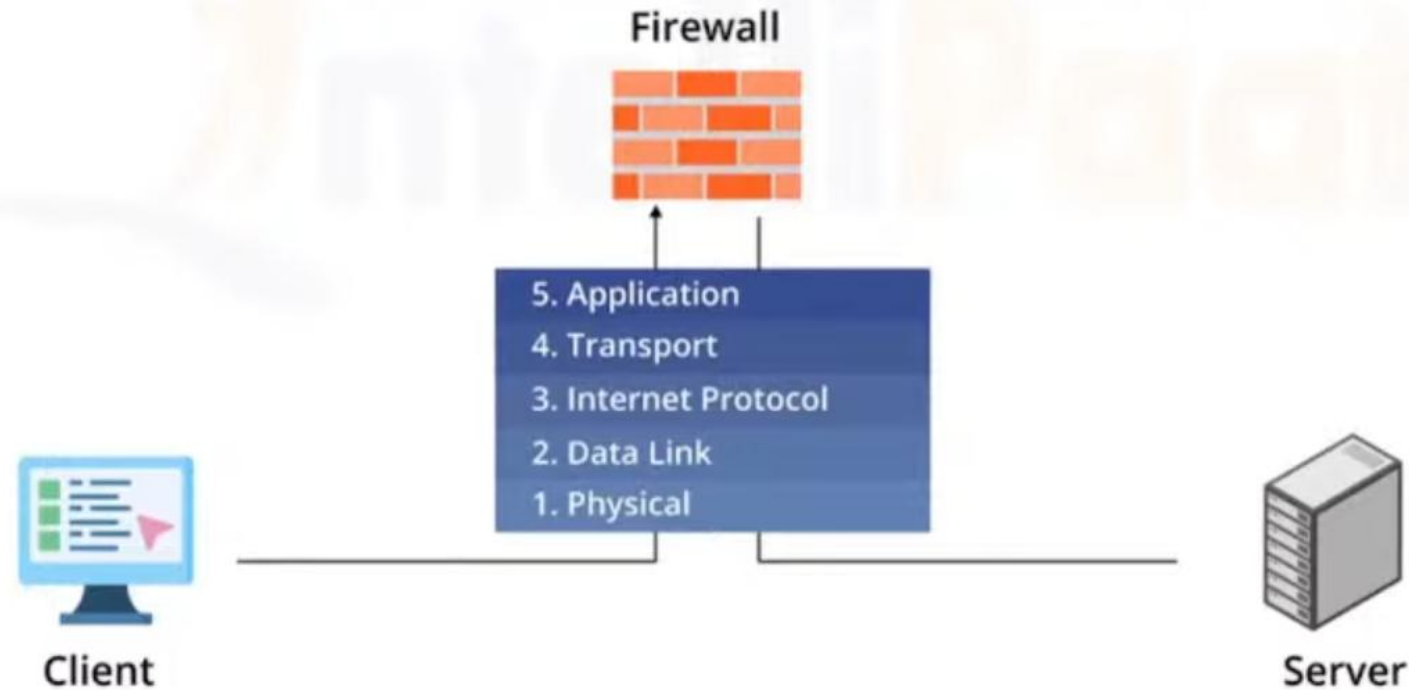
NG Firewall

1. Identify applications regardless of port, protocol, evasive tactic or SSL
2. Identify users regardless of IP address
3. Protect in real-time against threats embedded across applications
4. Fine-grained visibility and policy control over application access / functionality
5. Multi-gigabit, in-line deployment with no performance degradation



Stateful FW (Gen 3)

A stateful inspection firewall, sometimes known as a "conventional" firewall, allows or blocks traffic based on state, port, and protocol.

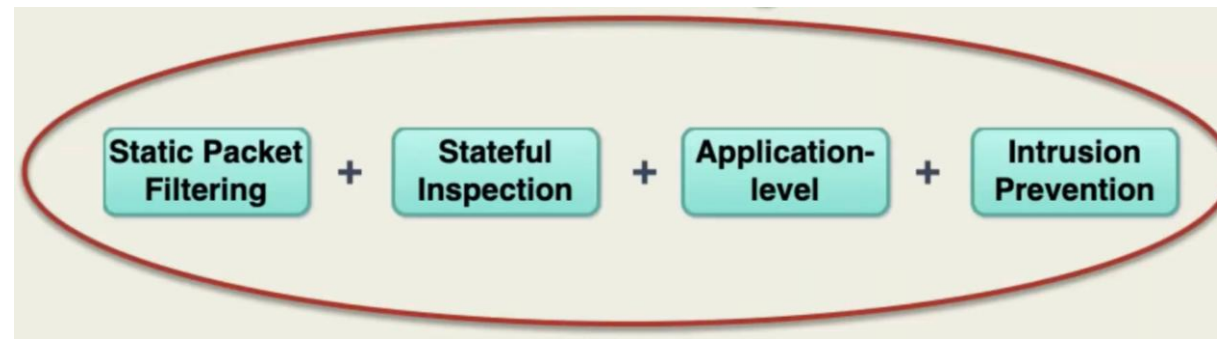
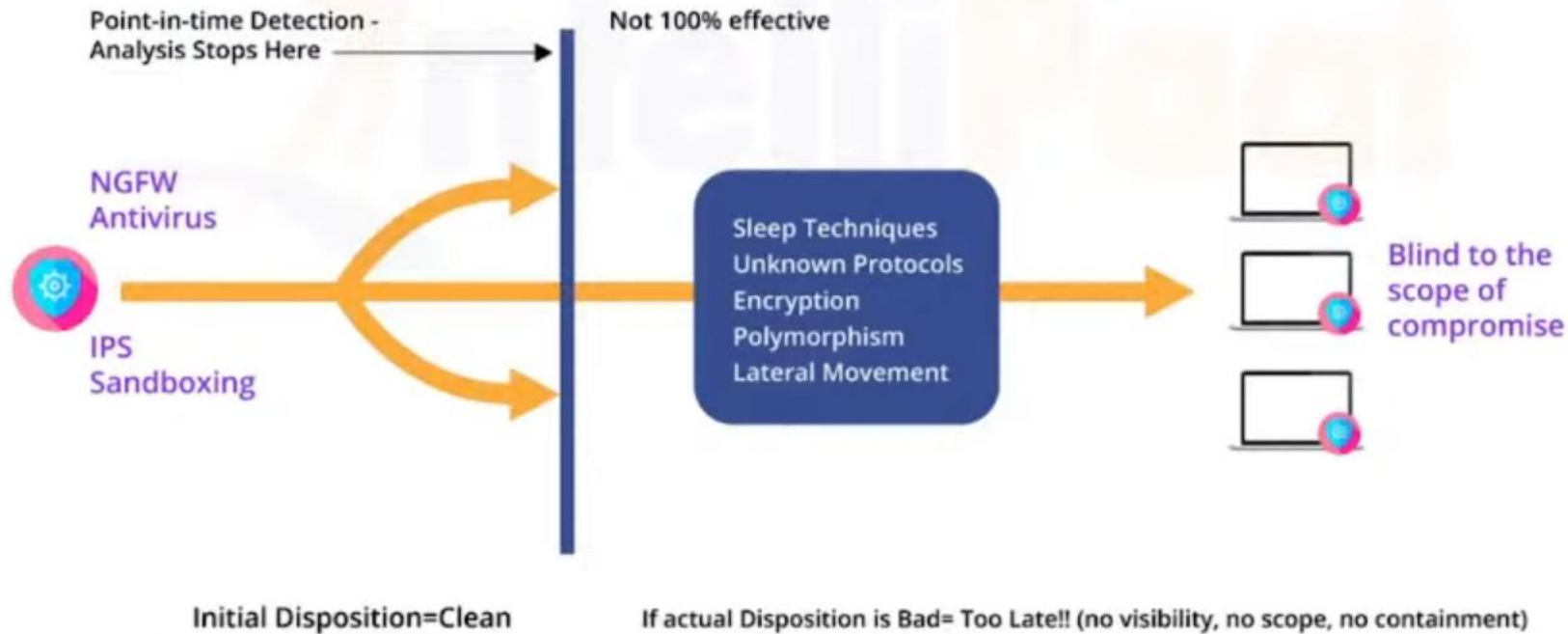


Inspects packets and also monitors for

- Malicious activities
- Suspicious commands
- Questionable session activity patterns

Next Generation NG-FW

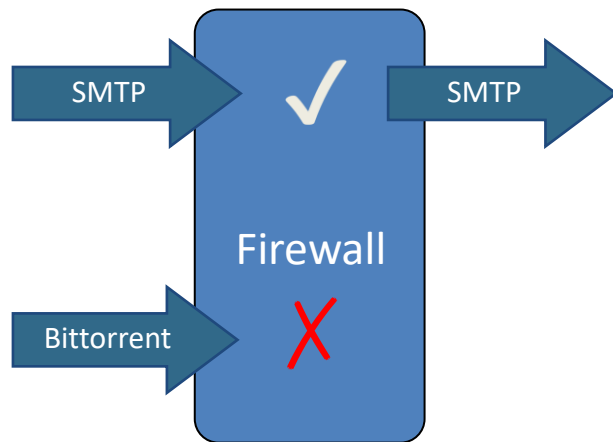
Threat-focused NGFW employ intelligent security automation to set security rules and policies, enhancing the overall defensive system's security.



NGFW vs. Legacy Firewalls

App-ID

Firewall Rule: ALLOW SMTP



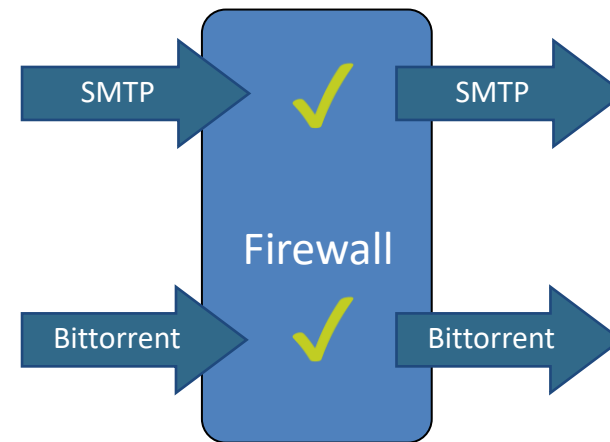
SMTP=SMTP: **Allow**

Bittorrent≠SMTP: **Deny**

Visibility: Bittorrent detected and blocked

Legacy Firewalls

Firewall Rule: ALLOW Port 25



Packet on Port 25: **Allow**

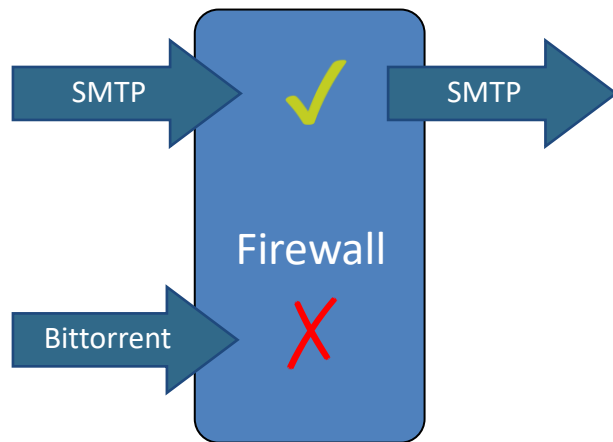
Packet on Port 25: **Allow**

Visibility: Port 25 allowed

NGFW vs. Legacy Firewall + App IPS

App-ID

Firewall Rule: ALLOW SMTP



SMTP=SMTP: Allow

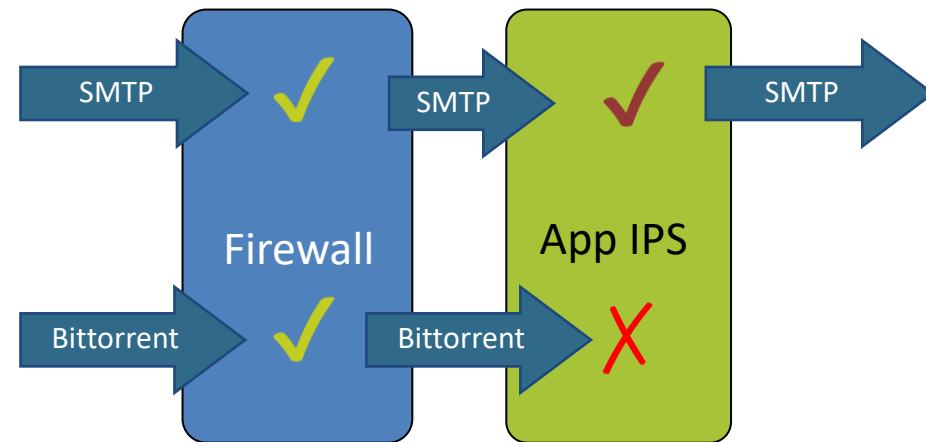
Bittorrent ≠ SMTP: Deny

Visibility: Bittorrent detected and blocked

Legacy Firewalls

Firewall Rule: ALLOW Port 25

Application IPS Rule: Block Bittorrent



Packet on Port 25: Allow

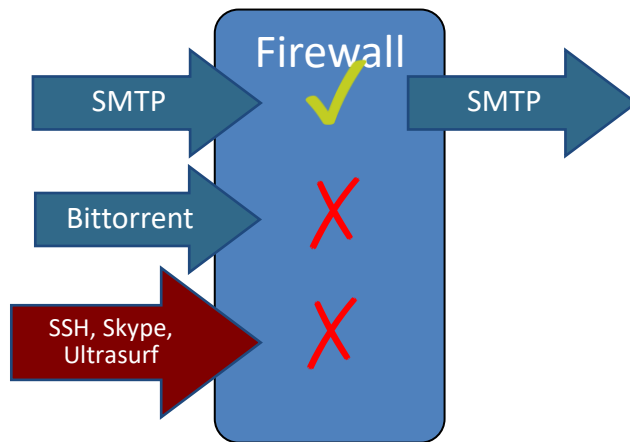
Bittorrent: Deny

Visibility: Bittorrent detected and blocked

NGFW vs. Legacy Firewall + App IPS

App-ID

Firewall Rule: ALLOW SMTP



SMTP=SMTP: Allow

Skype≠SMTP: Deny

SSH≠SMTP: Deny

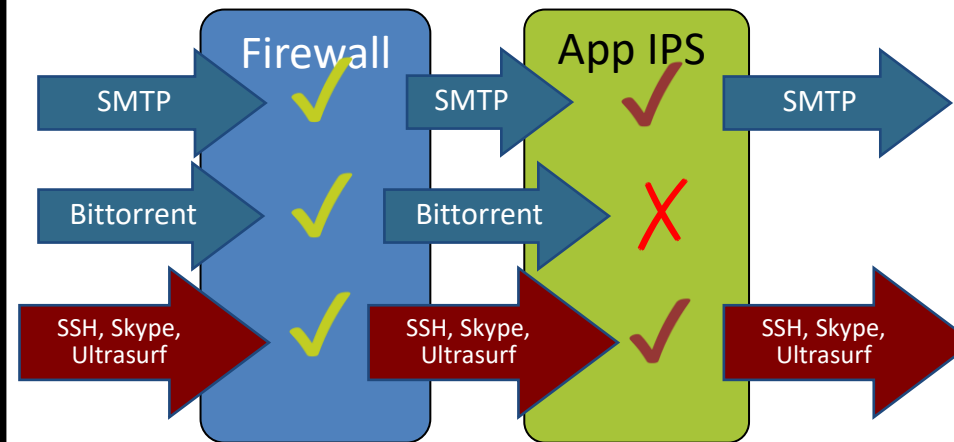
Ultrasurf≠SMTP: Deny

Visibility: each app detected and blocked

Legacy Firewalls

Firewall Rule: ALLOW Port 25

Application IPS Rule: Block Bittorrent



Packet on Port 25: Allow

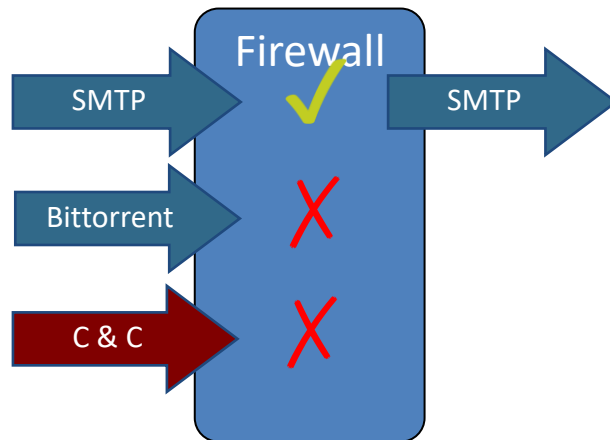
Packet ≠ Bittorrent: Allow

Visibility: Packets on Port 25 allowed

NGFW vs. Legacy Firewall + App IPS

App-ID

Firewall Rule: ALLOW SMTP



SMTP=SMTP: **Allow**

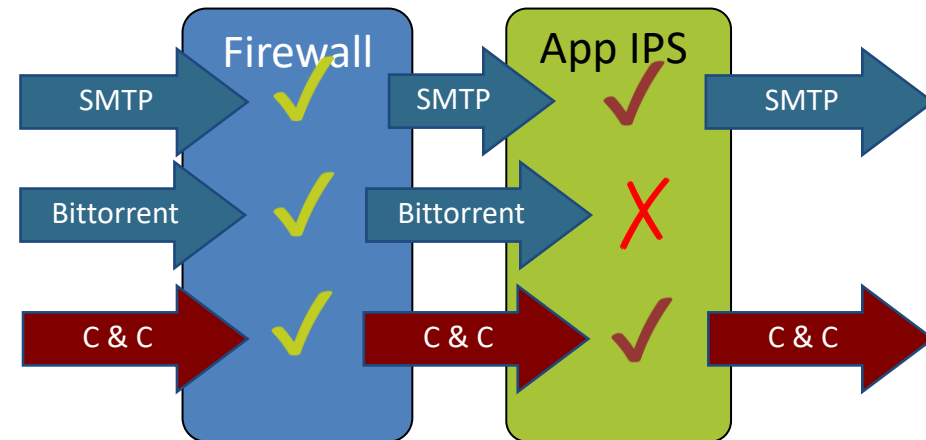
Command & Control ≠ SMTP: **Deny**

Visibility: Unknown traffic
detected and blocked

Legacy Firewalls

Firewall Rule: ALLOW Port 25

Application IPS Rule: **Block** Bittorrent



Packet on Port 25: **Allow**

C & C ≠ Bittorrent: **Allow**

Visibility: Packet on Port 25 allowed